

# SIMATS ENGINEERING

## ASSESSMENT TOOL 02

COURSE NAME: Ethical Hacking

COURSE CODE: ITA1410

### COURSE OUTCOME COVERED

*CO4: Implement network security testing methods by performing web server attacks, analyzing web application vulnerabilities, and assessing wireless network security using Kali Linux.*

QUESTIONS: 01

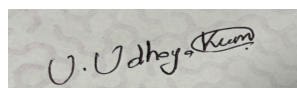
Total Marks:100

### Annexure A VULNERABILITY ASSESSMENT REPORT

#### Code of Conduct:

*I UDHAYAKUMAR U (192424332) (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.*

#### Signature of the student:



| S.No | Assessment Criterion                                 | Excellent                                                                                                                                                           | Good                                                                 | Satisfactory                                                                      | Needs Improvement                                                                  | Marks |
|------|------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------|-----------------------------------------------------------------------------------|------------------------------------------------------------------------------------|-------|
| 1    | Incident Background and Technical Understanding(20)  | Clearly explains the incident, timeline, affected organization, threat actor, wireless technology, and attack context.                                              | Explains most incident details with minor omissions.                 | Provides a basic incident summary but lacks technical depth.                      | Incident description is inaccurate, incomplete, or unclear.                        |       |
| 2    | Identification of Wireless Vulnerabilities(20)       | Accurately identifies vulnerabilities related to wireless standards, encryption, authentication, access points, configuration, and network architecture.            | Identifies most major vulnerabilities with reasonable explanation.   | Identifies only basic or obvious vulnerabilities.                                 | Fails to identify important vulnerabilities or provides incorrect findings.        |       |
| 3    | Risk, Impact, and Root-Cause Analysis(20)            | Provides a detailed analysis of attack vectors, root causes, affected assets, likelihood, and operational, financial, privacy, legal, and reputational impacts.     | Provides a good risk and impact analysis with minor gaps.            | Discusses general risks and impacts without sufficient justification.             | Risk analysis is weak, irrelevant, or unsupported.                                 |       |
| 4    | Security Recommendations and Mitigation Measures(20) | Proposes practical and well-justified controls involving secure authentication, encryption, segmentation, monitoring, access control, policies, and user awareness. | Recommends appropriate controls with minor omissions.                | Provides basic recommendations with limited technical detail.                     | Recommendations are impractical, incomplete, or unrelated to the identified risks. |       |
| 5    | Report Quality, Evidence, and Presentation(20)       | Report is well-structured, professionally written, supported by reliable references, diagrams, tables, and a clear risk-rating summary.                             | Report is clear and organized with suitable evidence and references. | Report is understandable but lacks organization, evidence, or proper referencing. | Report is poorly organized, unsupported, or contains major presentation errors.    |       |
|      |                                                      |                                                                                                                                                                     |                                                                      |                                                                                   | Total                                                                              |       |

## **Annexure A**

### **1.) TJX Companies Wireless Network Breach, 2005–2007**

#### **1.1 Executive Summary**

TJX Companies experienced a major payment-card data breach after attackers gained unauthorized access through its wireless network. The incident demonstrated the risks of using obsolete wireless encryption, inadequate wireless access controls, weak network segmentation, insufficient monitoring, and inadequate protection of sensitive payment information.

The main security weakness was the use of **WEP**, which was no longer suitable for protecting a corporate network carrying sensitive information. Once attackers gained wireless access, insufficient segmentation and monitoring increased the possibility of moving toward systems containing payment-card data.

#### **1.3 Wireless Encryption Weakness**

**WEP was designed as an early wireless security mechanism but has serious cryptographic weaknesses. An attacker who collected sufficient wireless traffic could potentially recover the encryption key.**

For a company processing payment-card information, relying on WEP created an unacceptable security risk.

#### **1.4 Authentication Weakness**

Wireless access should have required strong individual authentication rather than relying primarily on shared wireless credentials.

A better architecture would use:

- WPA2-Enterprise or WPA3-Enterprise
- IEEE 802.1X
- RADIUS authentication
- Strong individual credentials
- Digital certificates where appropriate
- Role-based access control

#### **1.5 Network Segmentation Weakness**

Wireless users should not have direct access to payment-card systems.

The network should be separated into:

**Guest Wi-Fi → Employee Wi-Fi → POS Network → Cardholder Data Environment → Management Network**

Firewalls and access-control lists should control communication between these zones.

## 1.6 Monitoring Weakness

The organization should have monitored:

- Unauthorized access points
- Rogue wireless devices
- Unknown client devices
- Suspicious authentication attempts
- Abnormal network traffic
- Lateral movement
- Access to payment systems

A **Wireless Intrusion Detection/Prevention System (WIDS/WIPS)** combined with a SIEM would improve detection.

## 1.7 Payment-Data Protection

Payment-card information should be protected through:

- PCI DSS controls
- Encryption of sensitive transmissions
- Strong access control
- Network segmentation
- Data minimization
- Secure configuration
- Logging and monitoring
- Vulnerability scanning and penetration testing

## 1.8 Recommended Controls

1. Completely eliminate WEP.
2. Implement WPA2-Enterprise or WPA3-Enterprise.
3. Use 802.1X/RADIUS authentication.
4. Segment wireless networks from POS and cardholder systems.
5. Deploy WIDS/WIPS.
6. Encrypt sensitive payment data.
7. Apply PCI DSS requirements.
8. Conduct regular wireless security assessments.

## 1.9 Conclusion

The TJX incident demonstrates that wireless security requires multiple layers of protection. Strong encryption alone is insufficient. **WPA2/WPA3-Enterprise, 802.1X authentication, network segmentation, wireless monitoring, and PCI DSS controls** could have significantly reduced both the likelihood and impact of the breach.

## 2.) Lowe's Wireless Network Intrusion, 2003

### 2.1 Executive Summary

In 2003, attackers compromised the wireless network of a Lowe's retail store and obtained access that could reach central corporate systems and other retail locations. The attackers attempted to install software designed to capture customers' credit-card information.

The major architectural problem was that a compromise of a **local wireless network could provide a path toward critical corporate and payment systems.**

**Overall Risk: Critical**

### 2.2 Vulnerability Assessment

| Security Area           | Vulnerability                                | Risk     |
|-------------------------|----------------------------------------------|----------|
| Wireless Authentication | Weak wireless access control                 | High     |
| Wireless Isolation      | Wireless users were insufficiently isolated  | Critical |
| Firewall                | Insufficient restrictions between networks   | Critical |
| POS Segmentation        | Payment systems were not adequately isolated | Critical |
| Intrusion Detection     | Limited ability to detect compromise         | High     |
| Centralized Management  | Inadequate centralized access control        | High     |

### 2.3 Authentication Weakness

Wireless access should not depend on weak or shared credentials.

Recommended solution:

**Wireless Device → 802.1X → RADIUS → Authentication Server → Authorized Network**

This provides centralized control over users and devices.

### 2.4 Wireless Isolation

A compromised wireless client should not be able to communicate freely with other wireless clients or internal servers.

Controls should include:

- Client isolation
- VLAN separation
- Access-control lists
- Internal firewalls
- Deny-by-default policies

## 2.5 Firewall Weakness

The wireless network should not have unrestricted access to corporate systems.

A secure design would be:

**Wireless Network → Firewall → Restricted Services → Corporate Network**

Only explicitly required traffic should be permitted.

## 2.6 POS Segmentation

Point-of-sale systems should operate in a separate protected network.

For example:

**Guest Wi-Fi → Firewall → Blocked**

**Employee Wi-Fi → Firewall → Limited Business Services**

**POS Network → Highly Restricted**

**Corporate Network → Separate Security Zone**

This prevents a wireless compromise from directly reaching payment systems.

## 2.7 Intrusion Detection

IDS/IPS should monitor:

- Unauthorized wireless connections
- Malware traffic
- Port scanning
- Suspicious authentication
- Unauthorized software installation
- Unusual connections between stores and corporate systems

## 2.8 Centralized Access Management

A large retail organization should centrally manage:

- User accounts
- Wireless devices
- Authentication
- Access privileges
- Security policies
- Logs
- Account revocation

MFA should also be used for administrative and privileged access.

## 2.9 Recommended Controls

1. Implement WPA2/WPA3-Enterprise.
2. Use 802.1X/RADIUS.
3. Isolate wireless clients.
4. Segment POS systems.
5. Deploy internal firewalls.
6. Restrict store-to-store communication.
7. Deploy IDS/IPS and WIDS/WIPS.
8. Implement centralized IAM.
9. Monitor administrative access.
10. Conduct regular penetration testing.

## 2.10 Conclusion

The Lowe's incident demonstrates the importance of **defense in depth**. A compromised wireless network should never automatically provide access to corporate or payment systems. Strong authentication, wireless isolation, firewall controls, POS segmentation, IDS/IPS, and centralized access management would substantially reduce the attack surface.

## 3.) Firesheep and Public Wi-Fi Session Hijacking, 2010

### 3.1 Executive Summary

Firesheep demonstrated how attackers connected to the same open wireless network could capture unencrypted session cookies and impersonate authenticated users.

The important vulnerability was that some websites protected only the login process with HTTPS while later authenticated communication could occur through unencrypted HTTP.

**Overall Risk: High**

### 3.2 Vulnerability Assessment

| Security Area    | Vulnerability                                   | Risk     |
|------------------|-------------------------------------------------|----------|
| Open Wi-Fi       | Traffic could be observed by nearby attackers   | High     |
| Session Cookies  | Cookies could be exposed over HTTP              | Critical |
| HTTPS            | Not consistently enforced                       | Critical |
| HSTS             | Lack of downgrade protection                    | High     |
| VPN              | Users may have no additional network protection | Medium   |
| Client Isolation | Clients could attack each other                 | High     |
| Awareness        | Users may not understand public Wi-Fi risks     | Medium   |

### 3.3 Open-Network Authentication

Public Wi-Fi networks often provide limited assurance that users are connected to a trustworthy network.

The provider should:

- Use secure Wi-Fi configurations where practical.
- Isolate clients.
- Secure the captive portal.
- Protect administrative interfaces.
- Prevent direct communication between unrelated clients.

### 3.4 Session-Cookie Protection

A session cookie can represent an already authenticated user.

If the cookie is transmitted without encryption, an attacker could potentially obtain the cookie and reuse the session.

Recommended controls:

- Secure cookie attribute
- HttpOnly cookie attribute
- Appropriate SameSite settings
- Session expiration

- Session rotation after authentication
- Session invalidation during logout

### 3.5 HTTPS Enforcement

HTTPS should protect the **entire authenticated session**, not only the login page.

Secure flow:

**User → HTTPS → Web Server → Encrypted Session**

Insecure flow:

**Login HTTPS → Later HTTP → Session Cookie Exposed**

Therefore, all authenticated pages and APIs should require HTTPS.

### 3.6 HSTS

HTTP Strict Transport Security (HSTS) instructs browsers to use HTTPS for a domain.

It helps reduce:

- HTTP downgrade attacks
- Accidental HTTP connections
- Some man-in-the-middle scenarios

### 3.7 VPN

A VPN can provide an additional encrypted tunnel when using an untrusted public network.

However:

**VPN does not replace HTTPS.**

HTTPS should remain mandatory for protecting application-level communication.

### 3.8 Wireless Client Isolation

Client isolation prevents users connected to the same wireless network from directly communicating with each other.

This can reduce:

- Local network attacks
- Packet interception attempts
- Direct attacks against neighboring devices



### 3.9 User Security Awareness

Users should be trained to:

- Check for HTTPS.
- Avoid suspicious Wi-Fi networks.
- Use MFA.
- Keep browsers updated.
- Avoid ignoring certificate warnings.
- Use VPN when appropriate.
- Avoid sensitive transactions on suspicious networks.

### 3.10 Recommended Controls

1. Enforce HTTPS everywhere.
2. Enable HSTS.
3. Secure session cookies.
4. Implement MFA.
5. Enable wireless client isolation.
6. Recommend VPN use on untrusted networks.
7. Secure captive portals.
8. Provide security-awareness training.

### 3.11 Conclusion

The Firesheep incident demonstrated that **authentication without secure session protection is insufficient**. Full HTTPS, HSTS, secure cookies, client isolation, MFA, VPN use, and user awareness provide multiple layers of protection against session hijacking.

## 4.) DarkHotel Attacks Through Hotel Wi-Fi Networks

### 4.1 Executive Summary

The DarkHotel campaign targeted selected business executives and government officials through compromised hotel networks. Victims could be presented with fraudulent software-update prompts that delivered malware.

The incident demonstrates that hotel Wi-Fi can become an attack platform when captive portals, DNS services, third-party management systems, or update mechanisms are compromised.

**Overall Risk: Critical**

### 4.2 Vulnerability Assessment

| Security Area         | Vulnerability                                           | Risk     |
|-----------------------|---------------------------------------------------------|----------|
| Guest Authentication  | Weak assurance and potentially insecure access process  | High     |
| Captive Portal        | Potential manipulation or malicious redirection         | High     |
| DNS                   | DNS manipulation could redirect users                   | Critical |
| Network Segmentation  | Guest traffic could potentially reach sensitive systems | Critical |
| Third-Party Access    | Vendor privileges create supply-chain risk              | High     |
| Software Updates      | Fake updates could deliver malware                      | Critical |
| Malware Detection     | Targeted malware may evade basic detection              | High     |
| Privileged Monitoring | Compromised management systems could affect many users  | Critical |

### 4.3 Guest Authentication

Hotel Wi-Fi should use secure authentication and secure captive portals.

Administrative access must use:

- Strong authentication
- MFA
- Least privilege
- Centralized logging

### 4.4 Captive Portal Security

The captive portal should use HTTPS and secure certificates.

Security controls should include:

- HTTPS
- Certificate validation
- Secure administrative accounts
- Regular patching

- Secure configuration
- Monitoring of portal changes

## **4.5 DNS Integrity**

DNS manipulation can redirect users from legitimate websites to malicious destinations.

Recommended controls:

- Trusted DNS resolvers
- DNS monitoring
- DNS filtering
- Secure resolver configuration
- Detection of abnormal DNS requests

## **4.6 Network Segmentation**

The hotel should separate:

**Guest Network**

**Staff Network**

**POS Network**

**Building Management Network**

**Surveillance Network**

**Corporate/Administrative Network**

These networks should communicate only when required.

## **4.7 Third-Party Access**

Hotel vendors may manage Wi-Fi, servers, or other infrastructure.

Third-party access should use:

- MFA
- Least privilege
- Time-limited access
- Individual accounts
- Logging
- Periodic access reviews
- Contractual security requirements

## 4.8 Software Update Verification

One of the most important protections against fraudulent updates is **digital-signature verification**.

Software should be accepted only when:

**Software Package → Signature Verification → Trusted Publisher → Installation**

Unexpected update prompts should be treated as suspicious.

## 4.9 Malware Detection

Hotels should use:

- Endpoint Detection and Response (EDR)
- Antivirus
- Behavioral detection
- Application control
- Network monitoring
- Centralized SIEM

## 4.10 Privileged-System Monitoring

Security teams should monitor:

- Administrative logins
- Configuration changes
- Vendor connections
- DNS changes
- Firewall changes
- Suspicious outbound connections
- Repeated authentication failures

## 4.11 Recommended Controls

1. Secure captive portals.
2. Protect DNS infrastructure.
3. Implement strict network segmentation.
4. Require MFA for administrators and vendors.
5. Verify software signatures.
6. Deploy EDR.
7. Implement WIDS/WIPS.
8. Centralize security logs.
9. Monitor privileged accounts.
10. Conduct regular third-party security assessments.

## **4.12 Conclusion**

DarkHotel demonstrates that users should not automatically trust hotel Wi-Fi. Secure captive portals, DNS integrity, network segmentation, third-party access controls, digitally signed software updates, malware detection, and privileged-system monitoring are essential for protecting hotel networks and high-value guests.

## 5.) Marriott Wi-Fi Deauthentication Incident, 2014

### 5.1 Executive Summary

The Marriott case involved the use of equipment that transmitted Wi-Fi deauthentication messages and affected guests' ability to use personal hotspots. The FCC investigated the matter, and Marriott agreed to a **\$600,000 civil penalty**.

The case highlights an important wireless security issue: traditional 802.11 management frames can be vulnerable to spoofing, allowing attackers or improperly used equipment to disrupt wireless availability.

**Overall Risk: High**

### 5.2 Vulnerability Assessment

| Security Area           | Vulnerability                                          | Risk     |
|-------------------------|--------------------------------------------------------|----------|
| Deauthentication Frames | Can be spoofed on networks without adequate protection | High     |
| Availability            | Legitimate users can be disconnected                   | High     |
| Wireless Interference   | Unauthorized wireless activity can disrupt services    | High     |
| Management Frames       | Insufficient protection in legacy configurations       | High     |
| Detection               | Abnormal deauthentication may go unnoticed             | High     |
| Policy                  | Improper wireless enforcement can create legal risk    | Critical |

### 5.3 Deauthentication Frame Weakness

A deauthentication frame tells a wireless client that its connection is no longer valid.

In older wireless security configurations, management frames were not adequately protected against spoofing.

Conceptually:

**Attacker/Unauthorized Device → Forged Deauthentication → Client Disconnects → Service Disruption**

This creates an **availability attack**.

### 5.4 Availability Risk

Unlike many attacks that target confidentiality, deauthentication attacks primarily target availability.

Possible consequences include:

- Users losing Wi-Fi connectivity
- Business disruption
- Increased support requests
- Interrupted online transactions
- Loss of productivity
- Damage to customer trust

## 5.5 Protected Management Frames

**Protected Management Frames (PMF)**, associated with IEEE 802.11w, provide protection for important wireless management traffic.

PMF helps prevent attackers from simply forging protected management messages.

Organizations should enable PMF wherever supported.

## 5.6 WPA3

WPA3 provides stronger modern wireless security and requires PMF for WPA3 connections.

Therefore, moving toward WPA3 can improve protection against management-frame attacks.

## 5.7 Wireless Intrusion Detection

WIDS/WIPS should monitor for:

- Excessive deauthentication frames
- Repeated disconnections
- Unknown access points
- Rogue devices
- Suspicious wireless behavior
- Abnormal channel activity

A sudden increase in deauthentication events should trigger an investigation.

## 5.8 Acceptable-Use Policy

Organizations should establish clear rules defining:

- Authorized wireless testing
- Authorized monitoring
- Permitted security tools
- Prohibited interference
- Incident escalation
- Vendor responsibilities
- Customer-impact considerations

Security testing should always have documented authorization and clearly defined scope.

## 5.9 Legal Consequences

Unauthorized interference with wireless communications can create regulatory and legal consequences.

The Marriott case demonstrates that organizations may face:

- Regulatory investigations
- Financial penalties
- Compliance consequences
- Reputational damage
- Civil or other legal exposure depending on the circumstances and jurisdiction

The legality of any wireless security action depends on applicable law, authorization, purpose, equipment, and the specific circumstances.

## 5.10 Recommended Controls

1. Enable Protected Management Frames.
2. Use WPA3 where supported.
3. Deploy WIDS/WIPS.
4. Monitor abnormal deauthentication activity.
5. Maintain wireless security baselines.
6. Establish acceptable-use policies.
7. Require authorization for wireless testing.
8. Maintain detailed wireless security logs.
9. Train administrators about lawful wireless security practices.
10. Conduct regular wireless security assessments.

## 5.11 Conclusion

The Marriott incident demonstrates that wireless security is not limited to protecting passwords and data. **Availability must also be protected.** PMF, WPA3, WIDS/WIPS, monitoring, security policies, and proper legal authorization can reduce the risk of wireless deauthentication abuse.